République Tunisienne
Ministère de l'Enseignement Supérieur
et de la Recherche Scientifique
École Supérieure Privée d'Ingénierie et de Technologie
TEK-UP

RAPPORT D'INVESTIGATION NUMÉRIQUE ET DE RÉPONSE À INCIDENT

Présenté dans le cadre du module

« Art de Protection des Secrets »

Diplôme National d'Ingénieur en Sciences Appliquées et Technologiques
Spécialité : Sécurité des Systèmes d'Information et des Réseaux (SSIR)

Réalisé par

Oussama Hamada & **Amir Ghdiri**

Encadré par

M. Oussama Bak Ali

Projet 4 — Réponse à Incident et Forensique

Intrusion par phishing et exfiltration de données sur le poste WKSTN01

Année Universitaire 2026 – 2027

Table des matières

1. Résumé exécutif 3
2. Contexte et périmètre 3
3. Intake et préservation des preuves 3
4. Méthodologie 4
5. Chronologie consolidée de l'intrusion 4
6. Findings — investigation hôte et SIEM (A) 6
7. Findings — investigation réseau & malware (B) 11
8. Chemin d'attaque & cartographie MITRE ATT&CK 15
9. Cause racine et impact 16
10. Indicateurs de compromission (IOCs) 16
11. Confinement, éradication, reprise et prévention 17
12. Limitations méthodologiques et verdict sur H3 17
13. Conclusion 18

1. Résumé exécutif

Le 2026-10-07, le poste WKSTN01 (192.168.100.40) a été compromis au cours d'une attaque simulée entre ~14:00 et 15:30 UTC. L'accès initial provient de l'exécution d'un exécutable malveillant (invoice_october.exe, déguisé en facture) téléchargé en HTTP depuis la machine attaquante Kali (192.168.100.30). Le binaire — un stager Meterpreter reverse TCP x64, identifié par analyse statique (strings, règle YARA) et par VirusTotal — a ouvert un canal de commande-et-contrôle (C2) sur le port 4444, inscrit une clé de persistance dans le registre, puis exfiltré un fichier de données clients simulées vers l'attaquant. Le SIEM Wazuh a reçu la télémétrie en temps réel et a levé des alertes d'exécution suspecte de cmd.exe pendant la session C2.

Technique ATT&CK	Verdict
T1566.001 — Phishing (livraison)	Confirmée (réseau + hôte + SIEM)
T1204.002 — Exécution utilisateur	Confirmée (Sysmon 1 + 4688 + Prefetch)
T1547.001 — Persistance (clé Run)	Confirmée (écriture) — non armée
T1059.003 — Shell cmd via C2	Probable (alerte Wazuh + Prefetch)
T1003.001 — Vol de credentials (LSASS)	Non concluante (aucune preuve positive)
T1041 — Exfiltration	Confirmée (PCAP + fichier reçu + hôte)

Sévérité : Élevée. Compromission complète d'un poste avec exfiltration de données sensibles confirmée. Le vol de credentials n'ayant pu être ni prouvé ni écarté, le compte local est traité comme compromis par précaution. Aucun mouvement latéral (poste unique, pas de contrôleur de domaine).

2. Contexte et périmètre

Élément	Détail
Incident	Intrusion ciblée avec exfiltration (Data Breach), initiée par phishing (simulation académique, données fictives)
Fenêtre	2026-10-07, 14:00:03Z → ~15:23Z (fin du canal C2)
Victime	WKSTN01 — 192.168.100.40 — Windows 10 Pro, Sysmon + agent Wazuh
Attaquant	Kali — 192.168.100.30 — Metasploit / msfvenom
SIEM	Wazuh — 192.168.100.10 (réutilisé du projet LogSentinel)
Équipe	A — Oussama Hamada (hôte / endpoint + SIEM) · B — Amir Ghdiri (réseau / malware)
Hors scope	Mouvement latéral, contrôleur de domaine, tout poste autre que WKSTN01

3. Intake et préservation des preuves

Les preuves ont été scellées lors de la phase de préparation (S0) — mémoire (.vmem), disque (.vmdk), capture réseau (PCAP), journaux Windows (.evtx), alertes Wazuh et binaire malveillant — chaque fichier étant haché en SHA-256 dans MANIFEST.sha256. Elles ont ensuite été copiées sur la station d'analyse (SIFT) puis re-vérifiées : 40 fichiers OK, 0 FAILED.

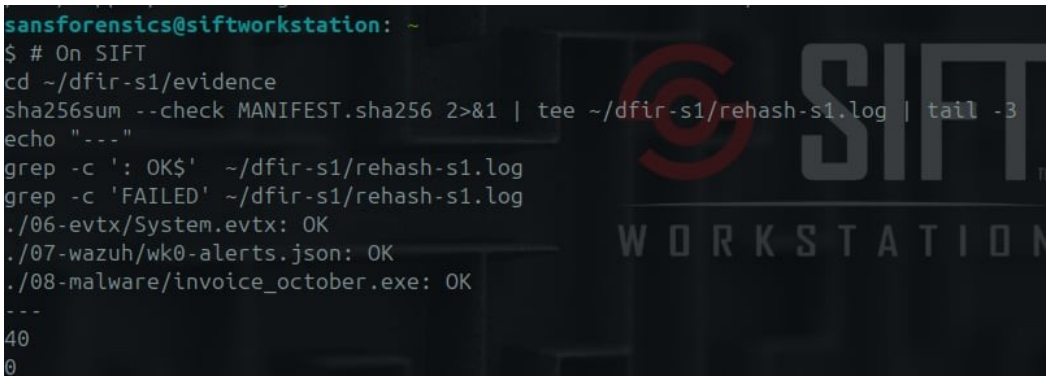


***Figure 1** — Re-vérification d'intégrité du coffre sur la station SIFT (sha256sum --check) : 40 OK, 0 FAILED*

Côté B, les trois preuves réseau reçues (wk0.pcap, exfil_20261007T150854Z.bin, attack.log) ont été re-hachées et comparées à MANIFEST-amir.sha256 : concordance exacte, aucune altération entre la collecte et l'analyse.

> **Anomalie de collecte signalée — intégrité préservée**
>
> Le fichier mémoire du coffre provient d'un suspend du 10-10, pas de la fenêtre d'attaque du 07-10 (écrasement par les cycles resume/suspend requis pour l'export .evtx). Le MANIFEST reste valide — aucune altération post-scellement. Le disque, les EVTX et le SIEM couvrent bien la fenêtre d'attaque et suffisent à établir H1, H2, H4 et H5. Conséquence : seule H3 (accès LSASS) perd son outil principal (voir §12).

4. Méthodologie

Voie	Outils	Analyste
Mémoire	Volatility 3 (pslist, pstree, netscan, malfind) — limitée par l'anomalie .vmem	A
Disque / fichiers	qemu-nbd + ntfs-3g (montage lecture seule), horodatages MFT, Prefetch	A
Registre / persistance	hivexsh sur ruche NTUSER.DAT montée en lecture seule	A
Journaux Windows	evtx_dump.py (Security, Sysmon, PowerShell/Operational)	A
SIEM	Wazuh Discover (index wazuh-alerts-*, filtre agent.name, fenêtre temporelle)	A
Trafic réseau	Wireshark (filtres IP / HTTP / TCP, Follow HTTP Stream)	B
Triage malware	tshark --export-objects, file, strings, YARA (règle dédiée), VirusTotal	B

> **Note sur les horodatages (lecture préalable à la chronologie)**
>
> Toutes les heures du rapport sont en UTC. WKSTN01 est synchronisé sur le SIEM ; Kali ne l'est pas : un décalage de quelques secondes entre horodatages hôte et réseau est attendu, et la corrélation inter-sources se fait aussi par séquence et par contenu (taille 133 o, URL, port, empreinte). Les valeurs t=…s de l'analyse réseau sont relatives au début de capture (14:00:03Z = t=0).
>
> Le tableau de bord Wazuh affiche les horodatages dans le fuseau du navigateur (UTC+1). Preuve : l'événement Sysmon de la Figure 7 porte utcTime 14:09:48 alors que Wazuh l'affiche à 15:09:49. Les heures lues sur les captures Wazuh sont donc converties (−1 h).

5. Chronologie consolidée de l'intrusion

Source : **H** = hôte, **R** = réseau/PCAP, **J** = journal attack.log, **S** = SIEM Wazuh.

UTC (approx.)	Src	Événement	Technique
14:00:03	J	Début capture tcpdump (t=0)	—
14:03:12	J	Handler Meterpreter (:4444) + serveur exfil (:8000) prêts	—
14:03:40 → 14:03:47	H+R	Premier téléchargement en échec : PowerShell 4100 (erreur, PID 5668) ↔ SYN/RST sur :8080 (t≈222 s)	—
14:07:03 (t=420 s)	R	1er GET /invoice_october.exe :8080 → 200	T1566.001
14:09:48	H+S	Sysmon 11 : dépôt Downloads\invoice_october.exe par powershell.exe (remonté au SIEM)	T1566.001
14:09:55 (t=592 s)	R	2e GET /invoice_october.exe :8080 → 200	T1566.001
15:01:30	H	Sysmon 3 : invoice_october.exe → 192.168.100.30:4444	T1071
15:01:32	H	Sysmon 1 : exécution PID 3568, parent PowerShell, Integrity High	T1204.002
~15:01:38 (t=3694 s)	R	Ouverture du canal C2 :4444 (~21 min)	T1071
15:01:40	H	Prefetch INVOICE_OCTOBER.EXE-45D1FC4B.pf (exécution effective)	T1204.002
15:01:53	H	Security 4688 (confirme l'exécution)	T1204.002
(fenêtre C2)	—	Vol de credentials supposé — non prouvé	T1003.001 (n/c)
15:05:09	H	Sysmon 13 : clé Run\WindowsUpdate = …\sysupdate.exe	T1547.001
15:05:54	H	MFT : création de Documents\customers.csv (133 o)	T1041

UTC (approx.)	Src	Événement	Technique
15:05:55	H	4688 : curl POST @customers.csv → :8000 (exfil #1)	T1041
15:08:33	H	Sysmon 11 : dépôt AppData\Roaming\sysupdate.exe	T1547.001
15:08:54 (t≈4137 s)	R+J	POST /exfil/customers :8000, 133 o reçus (exfiltration réussie)	T1041
15:09:53	H	4688 : 2e curl POST (retry)	T1041
15:12:17	J	« attack chain complete » (fin du journal opérateur)	—
15:21:21	H	Sysmon 3 : 2e connexion :4444	T1071
15:21:34	S	Alertes Wazuh 92052 / 92032 : cmd.exe lancé par un processus anormal	T1059.003
~15:22:54 (t=4971 s)	R	Fin du canal C2	—
15:27:37	H	Prefetch CMD.EXE-0BD30981.pf (dernière exécution de cmd.exe)	T1059.003

6. Findings — investigation hôte et SIEM (A)

6.1 Vecteur et exécution

La livraison du payload est tracée dans le journal PowerShell/Operational (Script Block Logging) : Invoke-WebRequest vers http://192.168.100.30:8080/invoice_october.exe, exécuté par le processus PowerShell PID 5668. Un événement 4100 (erreur) du même processus à 14:03:40 est cohérent avec les tentatives refusées observées dans le PCAP à t≈222 s (serveur HTTP de l'attaquant pas encore prêt).

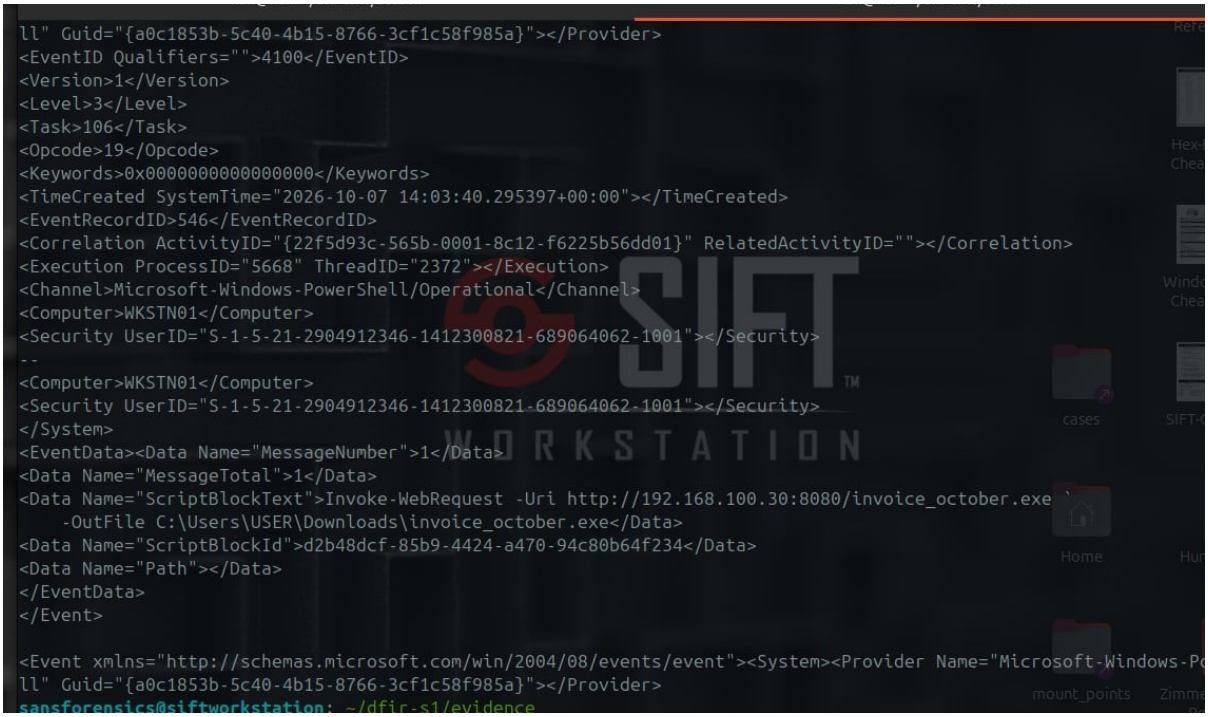


Figure 2 — Journal PowerShell/Operational : ScriptBlockText Invoke-WebRequest du payload depuis 192.168.100.30:8080 (PID 5668)

Le binaire a ensuite été exécuté (PID 3568, parent powershell.exe — et non un double-clic dans l'Explorateur), en contexte élevé (IntegrityLevel High). La convergence Sysmon 1 / Security 4688 / Prefetch établit l'exécution effective. Les empreintes du binaire sont relevées directement dans l'événement Sysmon 1 et sont identiques à celles du fichier extrait du PCAP (§7.4).

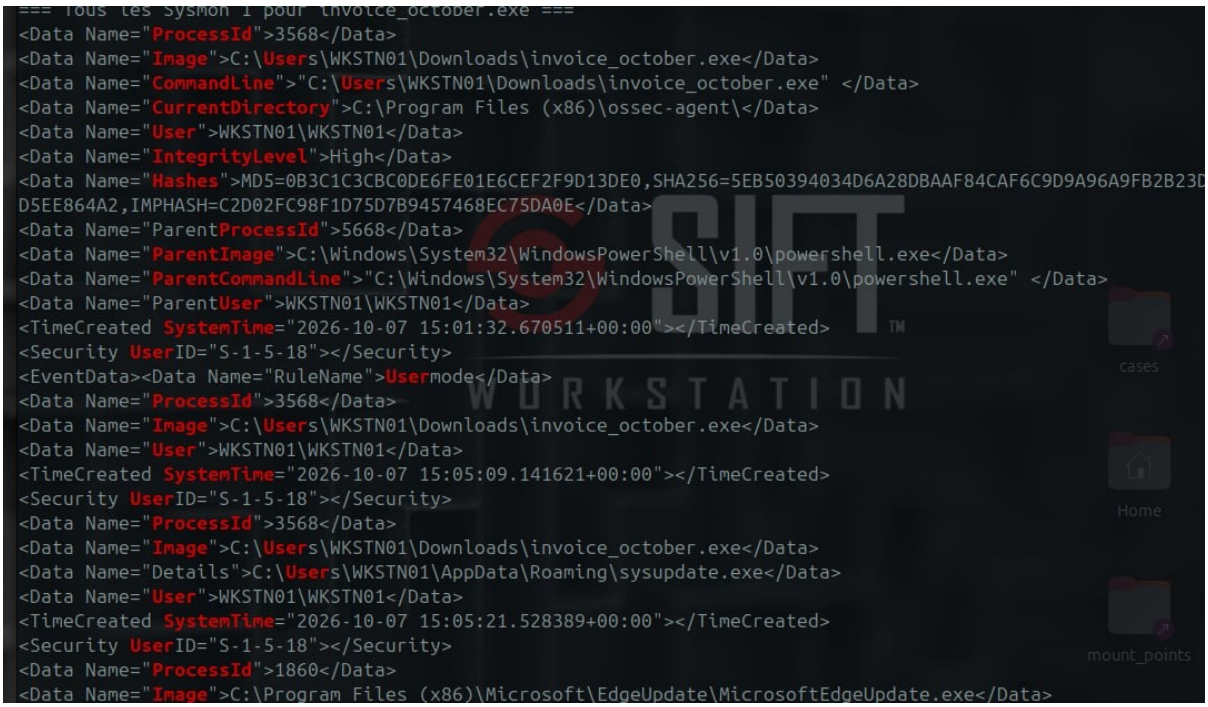


Figure 3 — *Sysmon : exécution de invoice_october.exe (PID 3568, parent PowerShell 5668, Integrity High, MD5/SHA-256/IMPHASH) et écriture de la valeur Run → AppData\Roaming\sysupdate.exe*

Attribut	Valeur
PID / parent	3568 / powershell.exe (PID 5668, WKSTN01\WKSTN01)
SHA-256	5EB50394034D6A28DBAAF84CAF6C9D9A96A9FB2B23D3A00CCF246E9D5EE864A2
MD5	0B3C1C3CBC0DE6FE01E6CEF2F9D13DE0
IMPHASH	C2D02FC98F1D75D7B9457468EC75DA0E
Taille	7 680 octets
IntegrityLevel	High

6.2 Persistance et artefacts disque

Sysmon Event 13 (15:05:09) enregistre l'écriture de la valeur HKCU\…\CurrentVersion\Run\WindowsUpdate = C:\Users\WKSTN01\AppData\Roaming\sysupdate.exe par le PID 3568 ; Sysmon Event 11 (15:08:33) enregistre le dépôt du binaire (T1547.001). L'image disque montée en lecture seule confirme le reste de la chaîne : le payload dans Downloads (14:09:48, 7 680 o), customers.csv dans Documents (15:05:54, 133 o) et les fichiers Prefetch d'exécution (INVOICE_OCTOBER.EXE à 15:01:40, CURL.EXE à 15:08:53, CMD.EXE à 15:27:37).

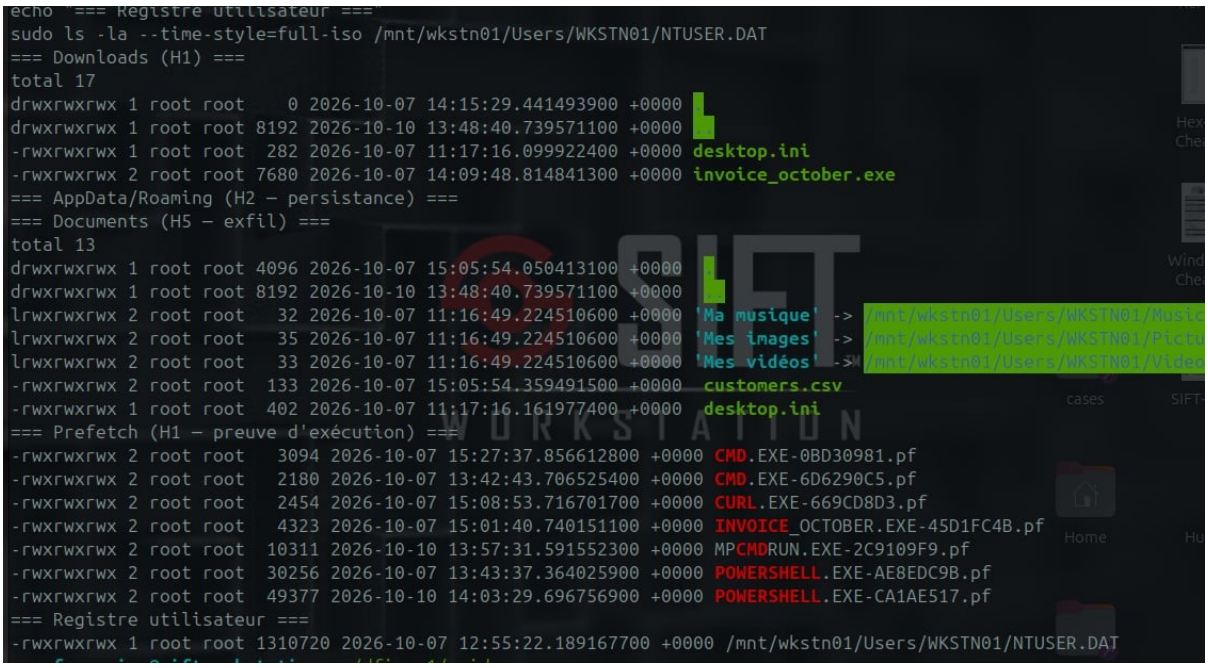


Figure 4 — *Artefacts disque (montage lecture seule) : Downloads, AppData\Roaming vide, Documents\customers.csv (133 o), Prefetch d'exécution, NTUSER.DAT*

> **Divergence documentée — persistance tentée, non armée**
>
> Sur l'état disque final, la ruche NTUSER.DAT ne contient que la valeur OneDrive (pas de WindowsUpdate), et AppData\Roaming ne contient pas sysupdate.exe (Figure 4). L'instrumentation (Sysmon) prouve que la persistance a été écrite ; l'état disque montre qu'elle n'est pas armée. Deux causes plausibles, non tranchées : ruche non flushée avant le suspend, ou profil nettoyé entre les sessions du 10-10. Verdict : confirmée (écriture) — non armée.

6.3 Accès aux identifiants (H3)

La recherche d'un accès à lsass.exe dans Sysmon ne renvoie aucune occurrence (section « B. lsass dans Sysmon » vide ; 0 Event 10 sur 13 115 événements). Mais la configuration Sysmon effectivement chargée n'a pas été préservée dans le coffre : impossible de prouver qu'elle journalisait cet accès. Combiné à l'anomalie mémoire (§3), l'hypothèse est classée non concluante — voir §12.

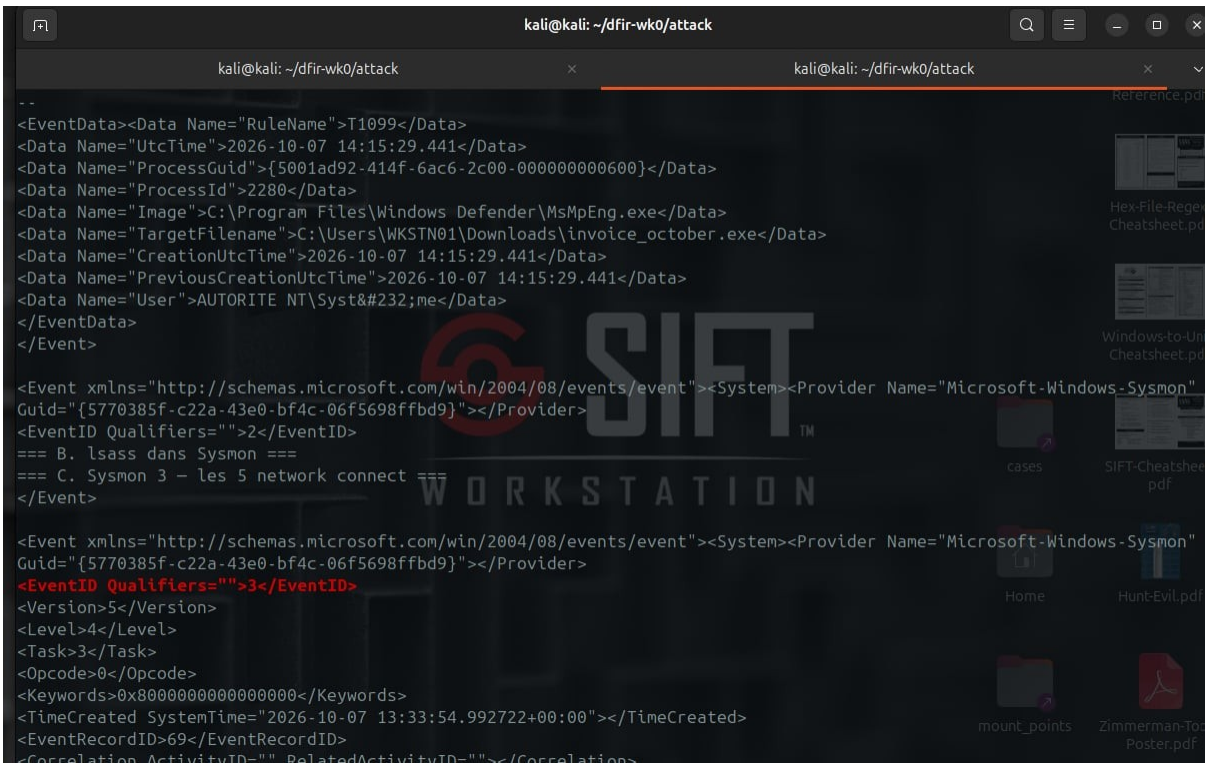


Figure 5 — *Recherche ciblée dans Sysmon : aucun accès à lsass.exe (section B vide) puis isolement des Event 3 (connexions réseau)*

6.4 Journaux de sécurité Windows

L'extraction de Security.evtx donne les volumétries d'événements (4624 = 207, 4625 = 1, 4688 = 773, 4672 = 179). Le 4625 unique (13:06:40, console locale) est bénin et antérieur à l'attaque. Côté hôte, l'exfiltration est établie par la chaîne MFT (customers.csv, 133 o) → 4688 (curl POST vers :8000) → Prefetch CURL.EXE.

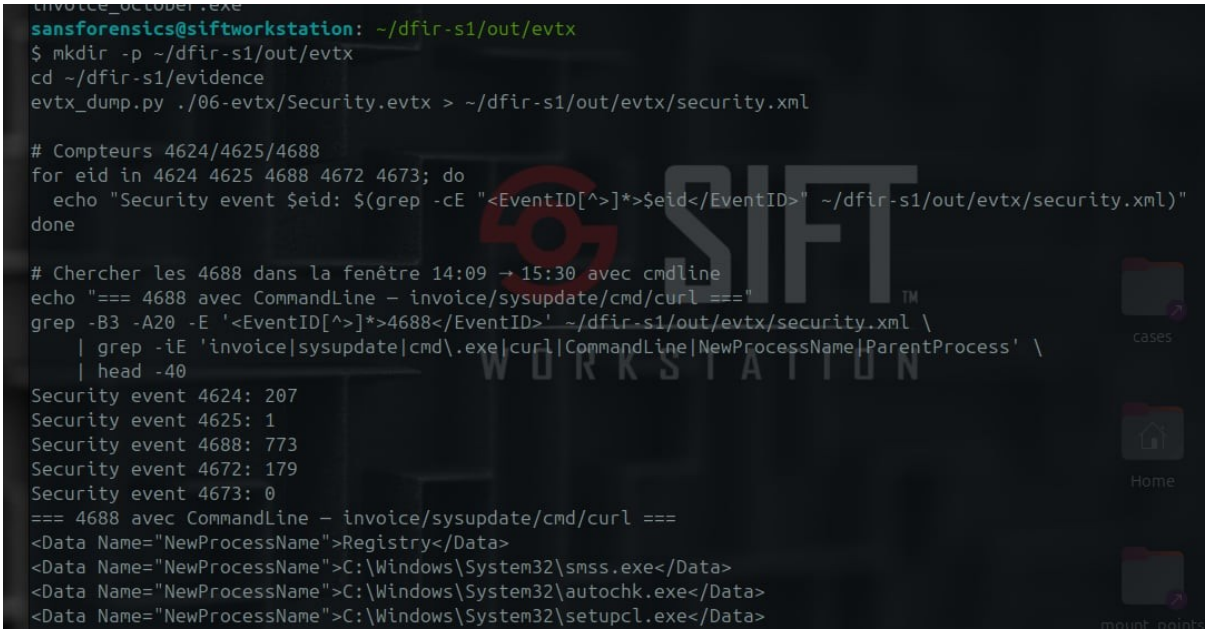


Figure 6 — *Extraction de Security.evtx (evtx_dump.py) : compteurs 4624 / 4625 / 4688 / 4672 et recherche des 4688 avec ligne de commande*

6.5 Corrélation SIEM (Wazuh)

Le SIEM a reçu en temps réel la télémétrie Sysmon et Windows de WKSTN01. Sur la fenêtre affichée, la requête agent.name:"WKSTN01" renvoie 649 événements ; l'événement de dépôt du payload y figure avec les mêmes champs que dans le Sysmon local (powershell.exe PID 5668, Downloads\invoice_october.exe, 14:09:48 UTC).

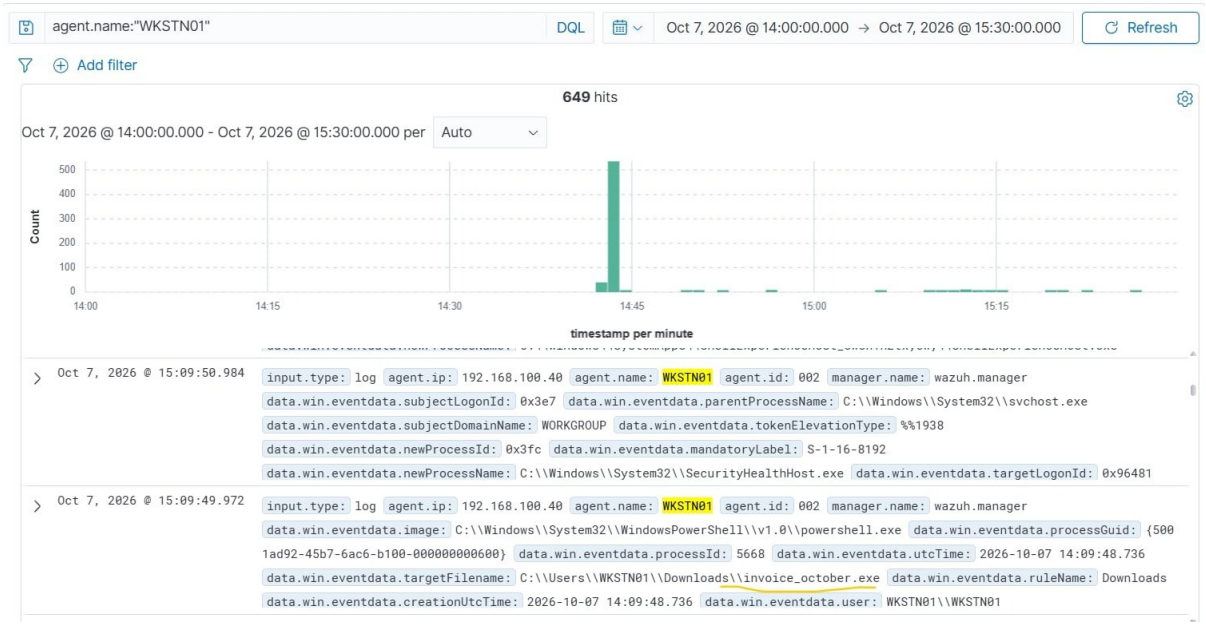


Figure 7 — *Wazuh Discover (wazuh-alerts-*, agent.name:"WKSTN01") : Sysmon 11, powershell.exe (PID 5668) crée Downloads\invoice_october.exe — utcTime 14:09:48 UTC (affiché 15:09:49 en heure locale)*

Sur la journée du 07-10, deux règles de détection ont tiré pendant la session C2 : 92052 « Windows command prompt started by an abnormal process » et 92032 « Suspicious Windows cmd shell execution », à 15:21:34 UTC — 13 secondes après la seconde connexion vers :4444 (Sysmon 3, 15:21:21).

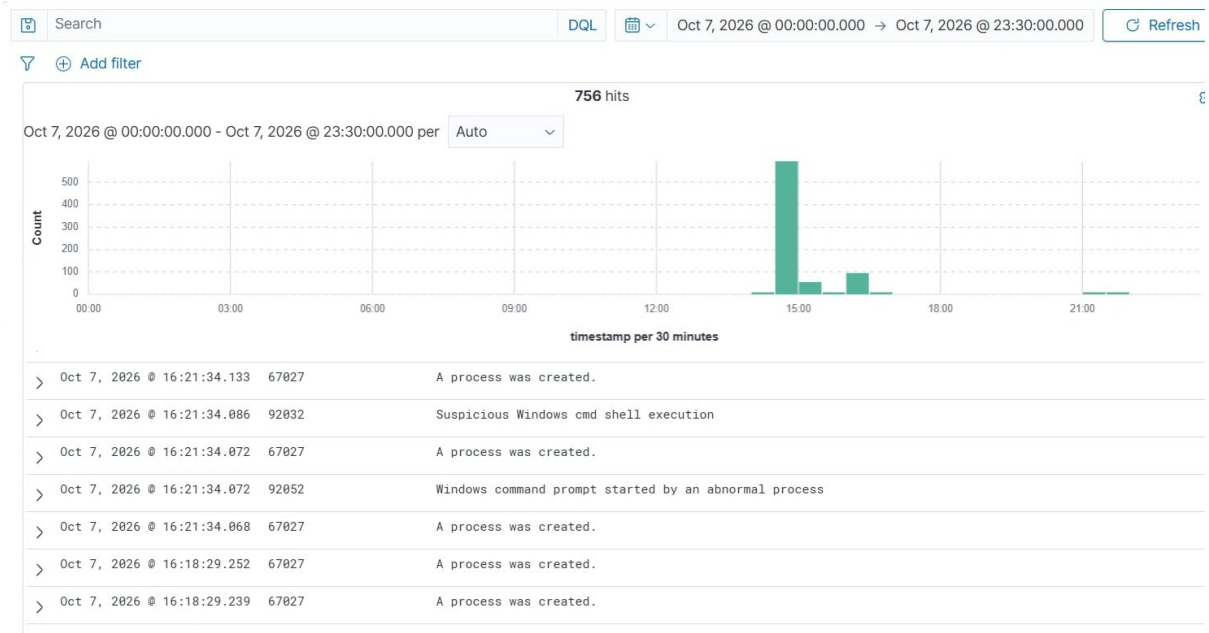


Figure 8 — *Wazuh Discover, journée du 07-10 : alertes 92052 et 92032 à 16:21:34 heure locale, soit 15:21:34 UTC, dans la fenêtre du canal C2*

Observation Wazuh	UTC	Interprétation
Pic d'environ 500 événements	~13:44	Antérieur à l'attaque : scan SCA de référence de l'agent et test du pipeline S0 (whoami, notepad, calc). Bénin, écarté.
Sysmon 11 — invoice_october.exe	14:09:48	Dépôt du payload : converge avec le Sysmon local et le 2e GET du PCAP.
Règles 92052 / 92032	15:21:34	cmd.exe lancé par un processus anormal, juste après une connexion C2 : shell interactif ouvert via Meterpreter probable (T1059.003). Corroboré par le Prefetch CMD.EXE (15:27:37).

Limite de détection constatée

Les alertes visibles relèvent de règles génériques (création de processus 67027, cmd suspect 92052/92032). Dans les vues capturées, ni la connexion C2 vers :4444, ni l'écriture de la clé Run, ni l'exfiltration n'ont déclenché d'alerte dédiée. Le parent exact de cmd.exe n'apparaît pas sur la capture : T1059.003 est donc classée probable, non confirmée. Ces lacunes motivent les règles proposées en §11.

7. Findings — investigation réseau & malware (B)

7.1 Trafic réseau (PCAP)

Le trafic brut est dominé par la télémétrie normale de l'agent Wazuh (WKSTN01 → 192.168.100.10:1514), écartée d'emblée. Le filtre sur l'IP attaquant isole les échanges malveillants et révèle, avant la livraison réussie (t=420 s), des tentatives de connexion sur :8080 immédiatement refusées (SYN → RST, t≈222–224 s).



***Figure 9** — Filtre ip.addr == 192.168.100.30 : échanges attaquant ↔ victime ; tentatives :8080 refusées (SYN → RST) avant la livraison*

Le filtre http isole trois échanges : deux GET /invoice_october.exe sur :8080 (réponses 200, application/x-msdos-program) qui confirment la livraison du payload, et un POST /exfil/customers sur :8000, environ 62 minutes plus tard.

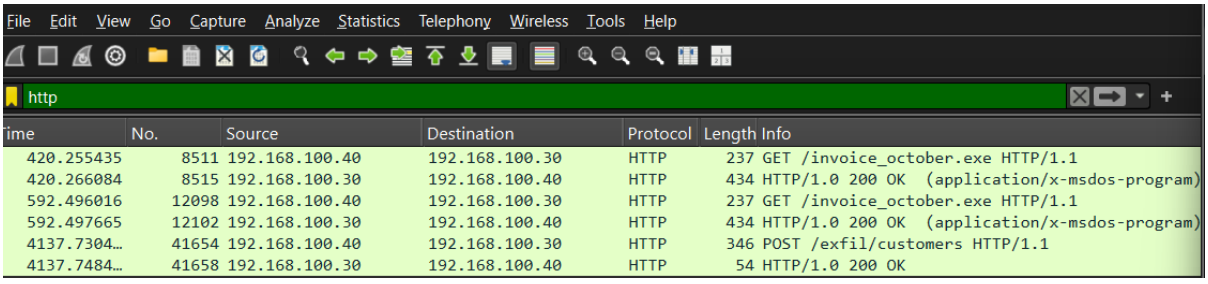


***Figure 10** — Filtre http : deux GET de livraison (:8080) et un POST d'exfiltration (:8000)*

7.2 Canal C2 Meterpreter

Le filtre tcp.port == 4444 confirme un canal C2 actif entre l'attaquant et la victime pendant ~21 minutes (t=3694 → 4971 s), qui englobe l'exfiltration. Le contenu est chiffré par Meterpreter : l'inspection applicative n'est pas

pertinente, et la persistance comme le vol de credentials, qui ne génèrent pas de HTTP, restent invisibles côté réseau.

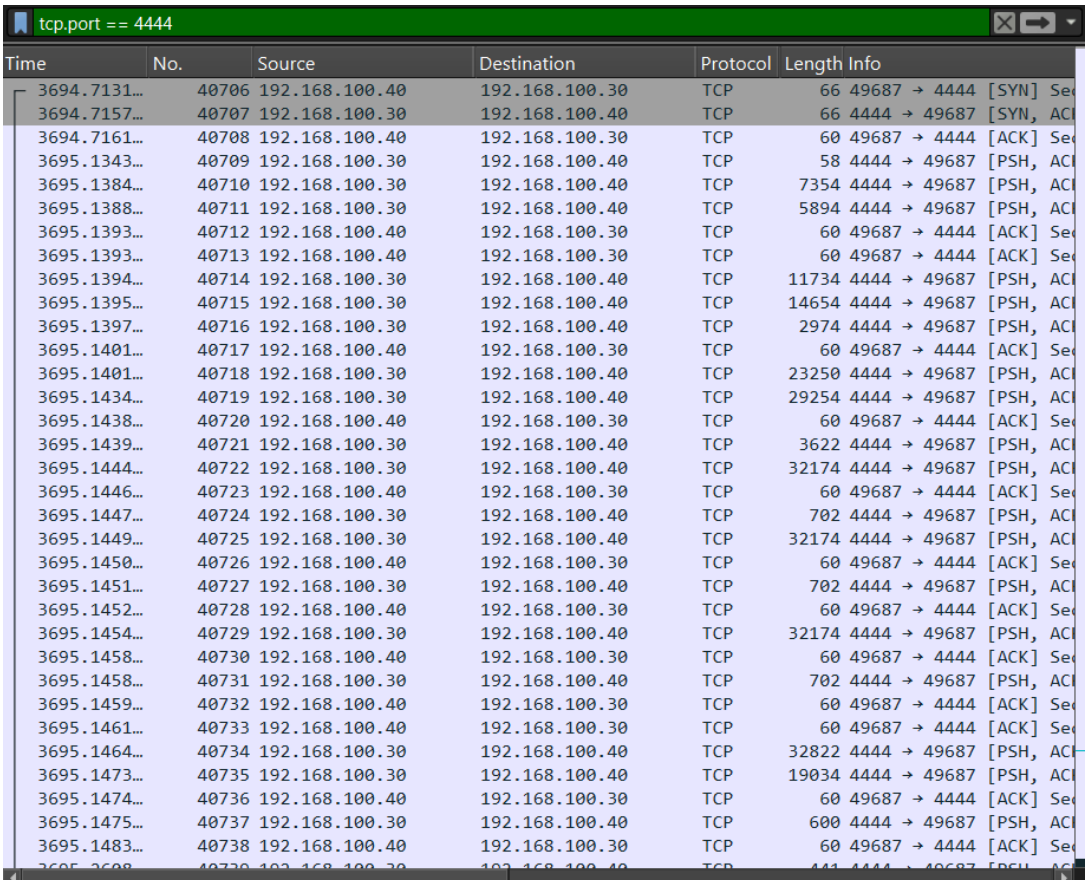


Figure 11 — *Filtre tcp.port == 4444 : canal C2 Meterpreter (~21 min)*

7.3 Contenu de l'exfiltration

La reconstruction du flux (Follow HTTP Stream) donne le contenu exact : un CSV de 133 octets (id, name, email, ssn ; 3 enregistrements, SSN simulés), transféré en clair. IOCs applicatifs : User-Agent curl/8.4.0 côté victime, serveur BaseHTTP/0.6 Python/3.13.12 côté attaquant. L'horodatage (15:08:54) coïncide avec la ligne de réception de attack.log.

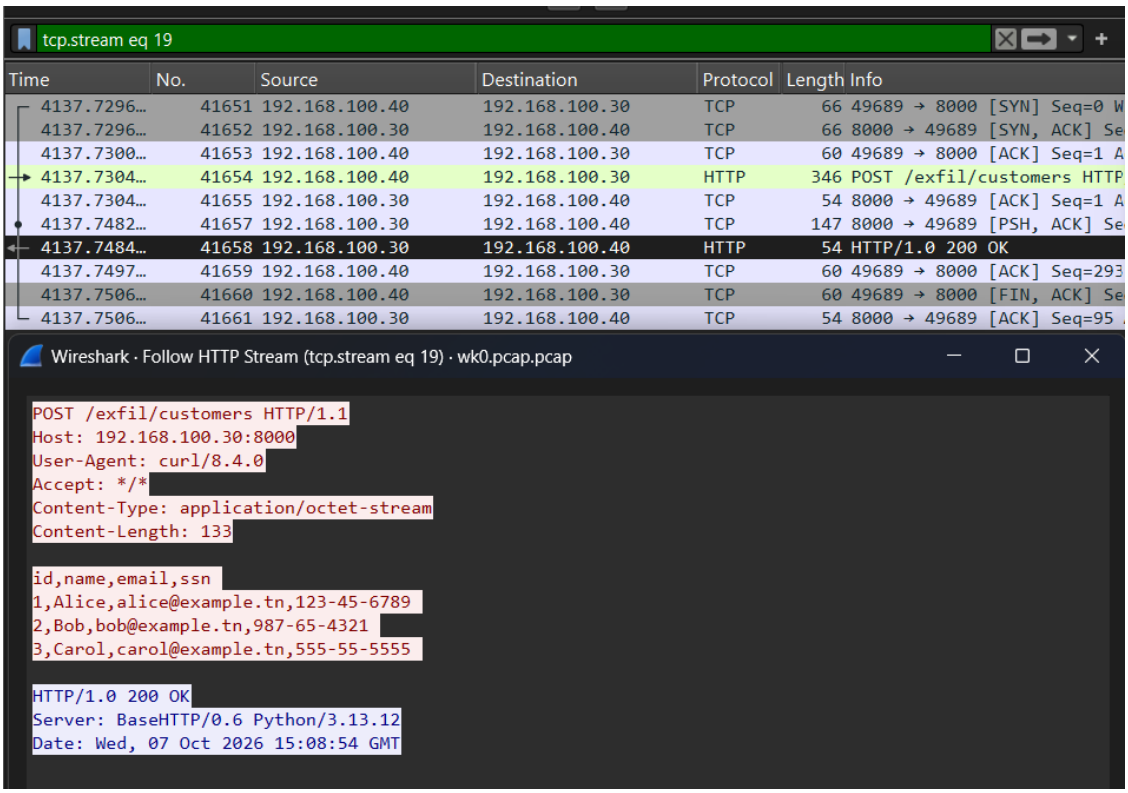


Figure 12 — *Follow HTTP Stream : POST /exfil/customers, corps CSV de 133 octets en clair (15:08:54)*

7.4 Triage statique du binaire malveillant

Le binaire a été extrait directement du PCAP (tshark --export-objects http). Son SHA-256 est identique à celui du coffre (08-malware) et à celui relevé dans l'événement Sysmon 1 : le fichier livré sur le réseau, le fichier présent sur disque et le processus exécuté sont un seul et même binaire. De même, l'objet customers extrait du PCAP a l'empreinte 5f682e65… du fichier reçu par l'attaquant (exfil_20261007T150854Z.bin).

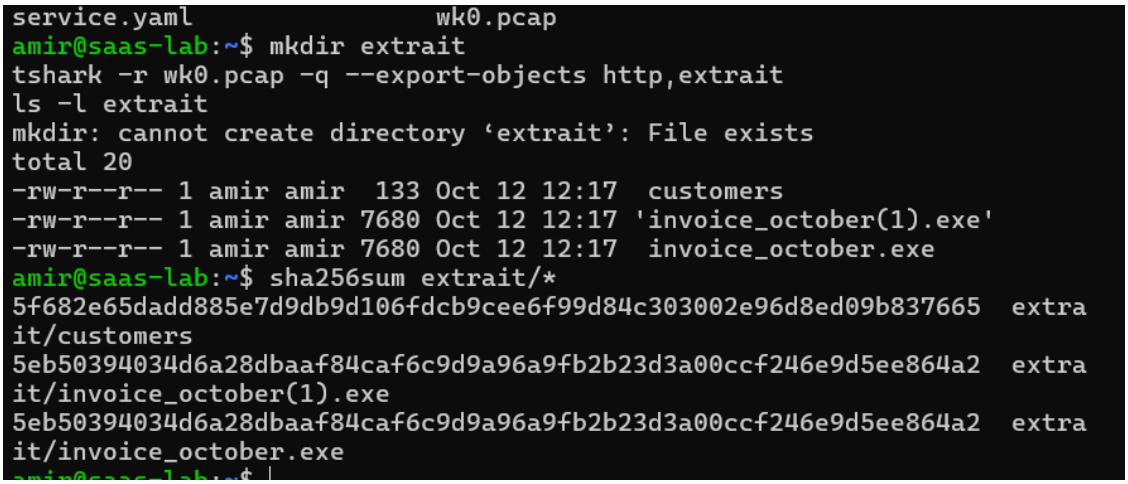


Figure 13 — *Extraction des objets HTTP du PCAP (tshark) et empreintes : invoice_october.exe = 5eb50394…, customers = 5f682e65…*

La commande file identifie un exécutable PE32+ (GUI) x86-64 à 5 sections — un programme Windows 64 bits, pas une facture. strings fait ressortir quatre indicateurs : une section au nom aléatoire .ifjf (les autres sont standards), le marqueur PAYLOAD: propre aux gabarits d'exécutables Metasploit, une seule API importée, VirtualProtect (rend exécutable la zone mémoire du shellcode), et ws2_32 présent uniquement en chaîne, signe que Winsock est chargé dynamiquement pour la connexion reverse TCP.

```
amir@saas-lab:~$ strings -a extrait/invoice_october.exe | head -60
!This program cannot be run in DOS mode.
Rich
.text
`.rdata
@.data
.pdata
@.ifjf
L$ A
.text$mn
.idata$5
.rdata
.rdata$voltmd
.rdata$zzzdbg
.xdata
.idata$2
.idata$3
.idata$4
.idata$6
.data
.pdata
VirtualProtect
KERNEL32.dll
PAYLOAD:
AQAPRH1
R VH
rPM1
AXAX^YZAXAYAZH
XAYZH
ws2_32
A^PPM1
j@AYh
}(XAWYh
unMa
KERNEL32.dll
VirtualProtect
```

Figure 14 — *strings -a sur invoice_october.exe : section .ifjf, PAYLOAD:, VirtualProtect, ws2_32*

Ces indicateurs ont été formalisés en une règle YARA (Stager_Meterpreter_invoice_october) : en-tête MZ, taille inférieure à 20 Ko et présence des quatre chaînes. La règle correspond au binaire, chaque chaîne étant localisée par son offset ; elle est réutilisable pour balayer d'autres postes (§11).

```
amir@saas-lab:~$ cat stager.yar
rule Stager_Meterpreter_invoice_october
{
    meta:
        description = "Stager Meterpreter reverse TCP x64 (invoice_octo
ber.exe)"
        author = "Amir"
        date = "2026-10-12"
        hash = "5eb50394034d6a28dbaaf84caf6c9d9a96a9fb2b23d3a00ccf246e9
d5ee864a2"
        reference = "T1566.001 / T1204.002"

    strings:
        $payload = "PAYLOAD:" ascii
        $vprotect = "VirtualProtect" ascii
        $ws2 = "ws2_32" ascii
        $section = ".ifjf" ascii

    condition:
        uint16(0) == 0x5A4D and
        filesize < 20KB and
        all of them
}
amir@saas-lab:~$
```

Figure 15 — *Règle YARA stager.yar écrite à partir des indicateurs statiques*

```
amir@saas-lab:~$ yara -s stager.yar extrait/invoice_october.exe
Stager_Meterpreter_invoice_october extrait/invoice_october.exe
0x800:$payload: PAYLOAD:
0x77a:$vprotect: VirtualProtect
0x1c48:$vprotect: VirtualProtect
0x1ad9:$ws2: ws2_32
0x270:$section: .ifjf
```

Figure 16 — yara -s : la règle correspond à invoice_october.exe (offsets 0x800, 0x77a, 0x1c48, 0x1ad9, 0x270)

La recherche par empreinte sur VirusTotal confirme la classification : 52 moteurs sur 71 détectent le fichier comme malveillant (marqueurs peexe, 64bits, spreader). Classification retenue : stager Meterpreter / Metasploit reverse TCP x64.

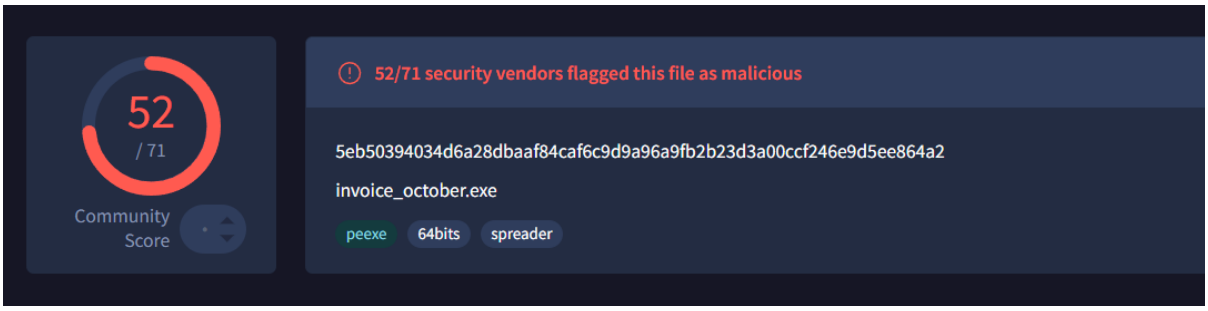


Figure 17 — VirusTotal : 52/71 moteurs détectent invoice_october.exe (SHA-256 5eb50394…)

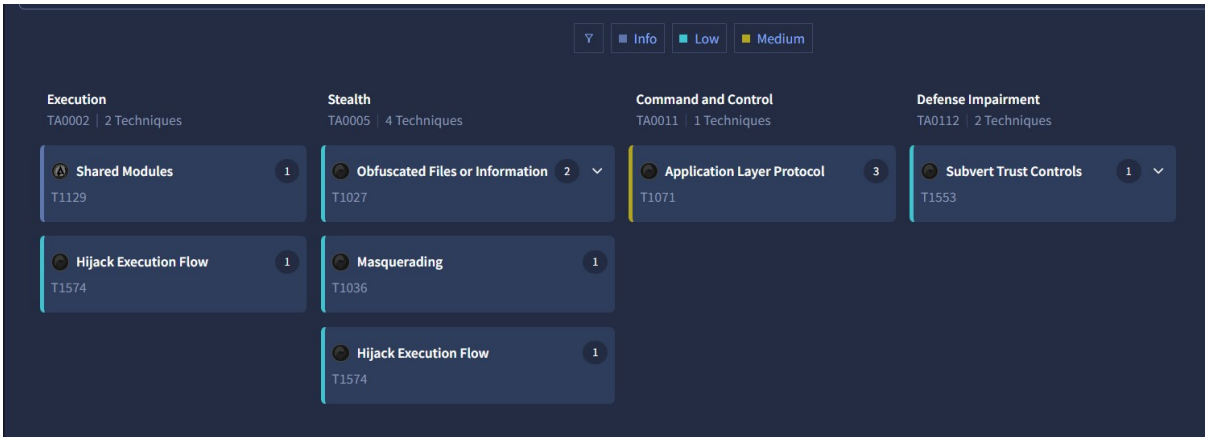


Figure 18 — VirusTotal : tactiques et techniques MITRE ATT&CK associées au binaire

> **Correction MITRE ATT&CK**
> La « tactique TA0112 — Defense Impairment » issue du triage automatique n'existe pas dans MITRE ATT&CK Enterprise : la technique correspondante, T1562 (Impair Defenses), relève de TA0005 (Defense Evasion). Corrigé dans le présent rapport. Ces techniques décrivent le comportement interne du binaire et complètent, sans les remplacer, celles de la chaîne globale.

8. Chemin d'attaque & cartographie MITRE ATT&CK

Étape	Technique	Verdict	Preuve principale
Livraison	**T1566.001**	Confirmée	PCAP 2× GET :8080 + log PowerShell + Sysmon 11 (local et Wazuh)
Exécution	**T1204.002**	Confirmée	Sysmon 1 + 4688 + Prefetch ; même SHA-256 que le binaire extrait du PCAP
C2	**T1071 / T1571**	Confirmée	Sysmon 3 (×2) + PCAP :4444 (~21 min)
Persistance	**T1547.001**	Confirmée (écriture) — non armée	Sysmon 13 + Sysmon 11 ; absente de NTUSER.DAT
Shell via C2	**T1059.003**	Probable	Alertes Wazuh 92052/92032 + Prefetch CMD.EXE
Credentials	**T1003.001**	Non concluante	aucune (voir §12)

Étape	Technique	Verdict	Preuve principale
Exfiltration	**T1041**	Confirmée	PCAP POST 133 o + attack.log + 4688 + MFT ; empreinte identique à exfil.bin

8.1 Rôle des ports (confirmé des deux côtés)

L'analyse réseau initiale signalait une « divergence » (livraison sur :8080 et non sur :4444/:8000). Il ne s'agit pas d'une contradiction mais d'une confirmation croisée : trois ports, trois rôles, chacun corroboré par les deux voies.

Port	Rôle	Preuve hôte	Preuve réseau
8080	Livraison du payload	Log PowerShell Invoke-WebRequest	2× GET HTTP 200
4444	Canal C2 Meterpreter	Sysmon 3 (×2)	Canal actif ~21 min
8000	Exfiltration HTTP	4688 curl POST (×2)	POST, corps 133 o

9. Cause racine et impact

9.1 Cause racine

L'accès initial résulte de l'exécution d'un exécutable malveillant déguisé en facture (facteur humain), dans un contexte d'exécution élevé (IntegrityLevel High) qui a donné à la charge des droits étendus dès le départ. Aucune vulnérabilité distante n'a été exploitée. Défenses contournées en amont : protection temps réel de Defender désactivée et dossier Downloads exclu.

9.2 Impact

Dimension	Évaluation
Confidentialité	Atteinte confirmée — exfiltration de customers.csv (données clients simulées)
Intégrité	Exécution de code arbitraire + dépôt d'un binaire de persistance
Disponibilité	Non affectée (pas de rançongiciel, pas de destruction)
Persistance	Tentée (clé Run + binaire) mais non armée sur l'état disque final
Identifiants	Risque non écarté (T1003.001 non concluante) — compte traité comme compromis
Périmètre	Un seul poste (WKSTN01) ; pas de mouvement latéral

Sévérité globale : Élevée. Compromission complète d'un poste avec exfiltration de données sensibles confirmée ; l'incertitude sur le vol de credentials impose de traiter le compte local comme compromis (rotation obligatoire, §11).

10. Indicateurs de compromission (IOCs)

Type	Valeur	Technique
IP attaquant	192.168.100.30	—
Ports	8080 (livraison) · 4444 (C2) · 8000 (exfil)	T1071 / T1041
URL livraison	http://192.168.100.30:8080/invoice_october.exe	T1566.001
URL exfiltration	http://192.168.100.30:8000/exfil/customers	T1041
Fichier	invoice_october.exe (stager Meterpreter reverse TCP x64, 7 680 o)	T1204.002
SHA-256	5eb50394034d6a28dbaaf84caf6c9d9a96a9fb2b23d3a00ccf246e9d5ee864a2	—
MD5 / IMPHASH	0B3C1C3CBC0DE6FE01E6CEF2F9D13DE0 / C2D02FC98F1D75D7B9457468EC75DA0E	—
Section PE	.ifjf (nom aléatoire)	—
Règle YARA	Stager_Meterpreter_invoice_october (stager.yar)	T1204.002

Type	Valeur	Technique
Clé Run	HKCU\...\Run\WindowsUpdate = ...\AppData\Roaming\sysupdate.exe	T1547.001
Fichier persistance	C:\Users\WKSTN01\AppData\Roaming\sysupdate.exe	T1547.001
Fichier exfiltré	C:\Users\WKSTN01\Documents\customers.csv (133 o, SHA-256 5f682e65...)	T1041
User-Agent	curl/8.4.0	T1041
Bannière serveur	BaseHTTP/0.6 Python/3.13.12	T1041
Prefetch	INVOICE_OCTOBER.EXE-45D1FC4B.pf · CURL.EXE-669CD8D3.pf	—
Alertes Wazuh	92052 / 92032 (cmd.exe lancé par un processus anormal)	T1059.003

Le jeu complet (27 entrées, format CSV) est fourni dans le fichier joint ***iocs-consolidated.csv***.

11. Confinement, éradication, reprise et prévention

Phase	Endpoint (A)	Réseau (B)
Confinement	Isoler WKSTN01, geler l'état (mémoire + disque), désactiver le compte, neutraliser l'auto-start	Bloquer l'IP Kali et les ports 4444/8000/8080 au pare-feu
Éradication	Supprimer le payload, sa copie et la clé Run ; scan AV + règle YARA Stager_Meterpreter_invoice_october	Vérifier l'absence de mouvement latéral
Reprise	Réimager le poste ; rotation des mots de passe	Remise en service après validation
Prévention	AppLocker/WDAC ; RunAsPPL + Credential Guard ; règles Wazuh/Sysmon dédiées	DLP/DPI en sortie ; HTTPS ; filtrage egress

11.1 Tableau contrôles → ATT&CK

Pour chaque technique de la chaîne, au moins un contrôle qui l'aurait bloquée (B) ou détectée (D).

Technique	Contrôle préventif / détectif	B/D
T1566.001 Phishing	Sensibilisation + filtrage des exécutables entrants (proxy bloquant application/x-msdos-program)	B
T1204.002 Exécution	AppLocker/WDAC (pas de binaire non signé depuis Downloads/AppData)	B
T1204.002 Exécution	Règle YARA Stager_Meterpreter_invoice_october (module YARA de Wazuh ou scan périodique)	D
T1547.001 Persistance	Règle Wazuh sur Sysmon 13 (écriture dans ...\CurrentVersion\Run)	D
T1059.003 Shell	Règles Wazuh 92052/92032 (actives — ont détecté l'incident), à corréler avec une connexion :4444	D
T1003.001 Credentials	RunAsPPL + Credential Guard	B
T1003.001 Credentials	Sysmon 10 sur lsass.exe (configuration préservée et vérifiée)	D
T1041 Exfiltration	DLP / inspection applicative (patterns SSN, e-mail) en sortie	B
T1071 / C2 :4444	Blocage egress des ports non standard + alerte Wazuh sur Sysmon 3 vers :4444 (règle 100100)	B+D

12. Limitations méthodologiques et verdict sur H3

Le vol de credentials (T1003.001) est le seul maillon de la chaîne qu'aucune voie d'analyse n'établit positivement :

Voie	Ce qu'elle montre pour H3
Hôte — Sysmon	Event 10 = 0 / 13 115, mais la configuration chargée n'est pas préservée → absence non interprétable
Hôte — mémoire	.vmem du 10-10, pas de la fenêtre d'attaque → malfind / arbre mémoire inexploitables
SIEM — Wazuh	Aucune alerte liée à lsass.exe dans les vues capturées (même limite de configuration)
Réseau — PCAP	Canal Meterpreter chiffré → « load kiwi » et dump non inspectables

Voie	Ce qu'elle montre pour H3
Malware — strings / YARA	Stager de 7 680 o avec une seule API importée : l'extension kiwi n'y figure pas, ce qui est attendu
Malware — VirusTotal	Techniques génériques du binaire, aucun indicateur mimikatz/kiwi

> **Analyse statique réalisée — elle confirme pourquoi H3 reste ouverte**
>
> Comme anticipé, strings et YARA confirment un stager Meterpreter et rien de plus. Dans Meterpreter, kiwi est une extension chargée réflexivement en mémoire via le canal C2 au moment de l'usage (« load kiwi ») : elle n'existe jamais dans le stager sur disque, dont la taille (7,5 Ko) exclut d'ailleurs tout embarquement. L'analyse statique ne pouvait donc pas trancher H3 ; elle était néanmoins nécessaire pour l'écarter comme source de preuve.

Verdict H3 : une activité compatible avec un accès aux identifiants a pu se produire pendant la fenêtre C2, mais elle n'a pas pu être confirmée de façon indépendante avec les preuves préservées. Classée non concluante, et non infirmée — conclusion fondée sur la preuve réelle plutôt que déduite du scénario.

13. Conclusion

L'investigation établit avec preuve directe quatre des cinq techniques de la chaîne (T1566.001, T1204.002, T1547.001, T1041) et confirme le canal C2 (T1071, port 4444) de façon indépendante côté hôte et côté réseau. Les empreintes relient sans ambiguïté le binaire livré sur le réseau, le fichier sur disque et le processus exécuté, ainsi que le fichier exfiltré capturé et le fichier reçu par l'attaquant. La persistance a été tentée mais n'était pas armée sur l'état disque final. Le SIEM a reçu la télémétrie et levé des alertes d'exécution suspecte de cmd.exe pendant la session C2, sans règle dédiée au C2 ni à la persistance. Le vol de credentials (T1003.001), bien que présent dans le scénario, ne peut être confirmé avec les preuves préservées. Les IOCs sont consolidés, une règle YARA de détection est livrée et un plan complet de confinement à prévention est proposé.

13.1 Leçons apprises

Leçon	Action pour les futurs projets
Anomalie mémoire	Capturer le .vmem avant tout cycle resume/suspend, ou le promouvoir immédiatement sous un nom horodaté
Configuration Sysmon non préservée	Archiver systématiquement sysmonconfig-export.xml dans le coffre (rend l'absence d'événement interprétable)
Fuseau horaire du SIEM	Régler le tableau de bord Wazuh en UTC (paramètre avancé dateFormat:tz) pour aligner les horodatages sur ceux des preuves
Couverture de détection	Ajouter avant l'exercice des règles dédiées C2 / clé Run / lsass, pour que le SIEM détecte et pas seulement collecte